

Charte de Conformité RGPD

Projet Alumni CRM - Version complete et fidele au code source

1. Contexte Juridique

Un annuaire d'anciens manipule avant tout des données personnelles : c'est le point de vigilance numéro un. La conformité repose ici sur une traçabilité complète des choix via la table CONSENTEMENT_RGPD, dans le cadre du Règlement (UE) 2016/679 (RGPD) et de la loi Informatique et Libertés. Deux limites à connaître : les données de consentement ne sont pas chiffrées au niveau applicatif (leur protection repose sur l'infrastructure PostgreSQL), et aucune fonctionnalité de notification de violation de données n'existe à ce jour.

2. Les 4 Types de Consentement Implémentés

Quatre consentements distincts sont proposés, chacun géré indépendamment par un toggle dédié dans l'interface alumni (AlumniConsent.jsx).

Type (Backend)	Clé Frontend	Description (simplifiée)	Exemple
prise_de_contact	contact_allowed	L'école ou ses partenaires peuvent contacter l'alumni.	Offres de postes, événements
partage_donnees	data_sharing	Données statistiques anonymisées partagées.	Secteur, poste
enquetes	survey_participation	Participation aux enquêtes alumni.	Évolution de carrière, satisfaction
newsletter	newsletter	Réception de la newsletter.	Actualités, offres d'emploi

3. Mécanisme de Gestion du Consentement

3.1 Collecte du consentement

- Canal principal : le formulaire d'inscription web (AlumniRegistration.jsx).
- Canal secondaire prévu : le questionnaire annuel (AlumniSurvey.jsx). À ce jour, seul le canal 'web' est réellement émis par le frontend.
- Chaque vote enregistre : type_consentement, statut (actif ou refuse), date_consentement, canal et id_etudiant.
- L'endpoint POST /consentements/ crée ou met à jour le consentement pour chaque type.
- L'interface de consentement rappelle la durée de conservation des données (suppression 6 mois après anonymisation) et affiche le contact du DPO (dpo@ionis-stm.com).

3.2 Modification et retrait

- L'alumni peut changer ses préférences à tout moment via l'interface de consentement.
- Le retrait est modélisé par un nouveau vote 'refuse', horodaté comme les autres.
- L'interface affiche la date de dernière mise à jour du consentement.
- Une suppression physique reste possible via DELETE /consentements/{id_consentement} (propriétaire ou

admin) ; le retrait usuel, lui, conserve l'historique complet des votes.

3.3 Traçabilité

- Date exacte du recueil enregistrée (date_consentement).
- Canal de collecte identifié de façon formelle (inscription ou questionnaire).
- Historique complet des votes conservé dans la base de données.

3.4 Consommation des consentements (relations fonctionnelles)

Chaque consentement est relié à un usage réel du système : un refus (statut 'refuse') désactive l'usage concerné. Tant que l'alumni n'a pas voté pour un type, il reste éligible (statut 'inconnu' toléré), ce qui est cohérent avec la suppression d'un consentement via DELETE /consentements/{id_consentement}. Le vote le plus récent est toujours déterminé par la même sous-requête corrélée (ORDER BY date_consentement DESC, id_consentement DESC LIMIT 1).

- 'newsletter' : autorise l'envoi des newsletters (POST /newsletter/envoyer, ciblage par promotion, secteur et consentements actifs).
- 'enquetes' : donne accès au questionnaire actif (GET /questionnaires/actif) et aux relances (POST /admin/questionnaires/notifier). Un refus bloque la restitution du questionnaire (HTTP 403) et masque le lien 'Enquête annuelle' dans la navigation alumni (AlumniLayout.jsx).
- 'prise_de_contact' : couvre newsletter et relances ; un refus exclut l'alumni des deux envois et c'est le seul consentement dont le refus déclenche l'anonymisation du profil (cleanup.py, CONSENTEMENT_ARCHIVE_TYPE = 'prise_de_contact').
- 'partage_donnees' : seuls les alumni ayant accepté le partage alimentent les indicateurs partenaires GET /admin/indicateurs/partenaires (comptages et moyennes anonymisés, aucune donnée personnelle transmise).

4. Droits RGPD Implémentés dans l'Interface

Dans l'interface alumni, ces droits sont à la fois affichés et réellement implémentés :

- Droit d'accès : page de profil en lecture seule, suivi des demandes via GET /rgpd/demandes/moi et export auto-service JSON/Excel/CSV via GET /rgpd/export.
- Droit de rectification et de mise à jour (AlumniProfile.jsx).
- Droit à l'effacement (droit à l'oubli) : workflow auto-service (POST /rgpd/demandes) traité par anonymisation puis purge différée.
- Droit de retirer son consentement à tout moment (AlumniConsent.jsx avec toggles).

5. Modèle de Données CONSENTEMENT_RGPD

Champ	Type	Contraintes (simplifiées)	Exemple
id_etudiant	Entier (FK)	REFERENCES ETUDIANT, NOT NULL.	42
type_consentement	Enum / Chaîne	4 valeurs possibles.	newsletter
date_consentement	Date	NOT NULL, date du jour.	2025-09-14
statut	Chaîne	actif (accordé) / refuse (retiré).	actif
canal	Chaîne	web questionnaire.	web

6. Workflow des Demandes RGPD (Effacement et Portabilité)

Au-delà des consentements, le CRM met en place un vrai circuit de traitement des droits d'accès, d'effacement et de portabilité, appuyé sur la table DEMANDE_RGPD :

- Dépôt auto-service : POST /rgpd/demandes (types 'export' ou 'suppression') ; l'alumni suit et annule ses demandes via GET /rgpd/demandes/moi et DELETE /rgpd/demandes/{id}.
- Cycle de statuts : envoyee -> en_traitement -> traitee/rejetee (contrainte SQL, migration 009), avec un verrou anti-traitement parallèle (prise_en_charge_par, date_prise_en_charge).
- Une demande de suppression est traitée par anonymisation irréversible (email remplacé par ANONYMISE_<id>@anonymise.io, données personnelles effacées), puis par purge physique différée après PURGE_DELAY_MONTHS mois (défaut 6) via purge.py (--dry-run disponible) ou POST /admin/demandes-rgpd/purge-anonymises.
- Portabilité : export auto-service JSON/Excel/CSV via GET /rgpd/export ; exports admin unitaires et en masse.
- Chaque opération est tracée dans AUDIT_LOG (acteur, action, détails).